

UNIVERSIDAD INDOAMÉRICA

FACULTAD DE INGENIERÍAS

INGENIERÍA EN TECNOLOGÍAS DE LA INFORMACIÓN

TEMA:

METODOLOGÍA PARA EL DIAGNÓSTICO Y GESTIÓN DE RIESGOS EN EL TRATAMIENTO DE DATOS PERSONALES

Trabajo de Titulación modalidad Trabajo de Integración Curricular

Autor

Ramon Alejandro Manzaba Castro

Tutora

Ing. Cristina Jiménez, MSc.

QUITO – ECUADOR

2026

AUTORIZACIÓN POR PARTE DEL AUTOR PARA LA CONSULTA, REPRODUCCIÓN PARCIAL O TOTAL, Y PUBLICACIÓN ELECTRÓNICA DEL TRABAJO DE INTEGRACIÓN CURRICULAR

Yo, Ramon Alejandro Manzaba Castro, declaro ser autor del Trabajo de Titulación con el nombre "Metodología para el diagnóstico y gestión de riesgos en el tratamiento de datos personales", como requisito para optar al grado de Ingeniero en Tecnologías de la Información y autorizo al Sistema de Bibliotecas de la Universidad Tecnológica Indoamérica para que, con fines netamente académicos, divulgue esta obra a través del Repositorio Digital Institucional (RDI-UTI).

Los usuarios del RDI-UTI podrán consultar el contenido de este trabajo en las redes de información del país y del exterior, con las cuales la Universidad tenga convenios. La Universidad Tecnológica Indoamérica no se hace responsable por el plagio o copia del contenido parcial o total de este trabajo.

Del mismo modo, acepto que los Derechos de Autor, Morales y Patrimoniales sobre esta obra serán compartidos entre mi persona y la Universidad Tecnológica Indoamérica, y que no tramitaré la publicación de este trabajo en ningún otro medio sin autorización expresa de la misma. En caso de que exista el potencial de generación de beneficios económicos o patentes, producto de este trabajo, acepto que se deberán firmar convenios específicos adicionales donde se acuerden los términos de adjudicación de dichos beneficios.

Para constancia de esta autorización, en Quito, Ecuador, a los xx días del mes de xx de 2026, firmo conforme:

Autor: Ramon Alejandro Manzaba Castro

Firma:

Número de Cédula: 1729303998
Dirección: Provincia, Quito, Quitumbe, San Martin de porres
Correo Electrónico: ramonalejandromanzaba@gmail.com
Teléfono: 0989224684

APROBACIÓN DE LA TUTORA

En mi calidad de Tutora del Trabajo de Titulación "METODOLOGÍA PARA EL DIAGNÓSTICO Y GESTIÓN DE RIESGOS EN EL TRATAMIENTO DE DATOS PERSONALES", presentado por Ramon Alejandro Manzaba Castro, para optar por el Título de Ingeniero en Tecnologías de la Información.

CERTIFICO

Que dicho Trabajo de Titulación ha sido revisado en todas sus partes y considero que reúne los requisitos y méritos suficientes para ser sometido a la presentación pública y evaluación por parte del Tribunal revisor que se designe.

Quito, Ecuador, xx de xx de 2026

Ing. Cristina Jiménez, MSc.

DECLARACIÓN DE AUTENTICIDAD

Yo, Ramon Alejandro Manzaba Castro, declaro que los contenidos y los resultados obtenidos en el presente Trabajo de Titulación "Metodología para el diagnóstico y gestión de riesgos en el tratamiento de datos personales", como requerimiento previo para la obtención del Título de Ingeniero en Tecnologías de la Información, son absolutamente originales, auténticos y personales y de exclusiva responsabilidad legal y académica del autor.

Quito, Ecuador, xx de xx de 2026

Ramon Alejandro Manzaba Castro
(Número de cédula)

APROBACIÓN DE LECTORES

El Trabajo de Titulación ha sido revisado, aprobado y autorizada su impresión y empastado sobre el tema "METODOLOGÍA PARA EL DIAGNÓSTICO Y GESTIÓN DE RIESGOS EN EL TRATAMIENTO DE DATOS PERSONALES", presentado por Ramon Alejandro Manzaba Castro, previo a la obtención del Título de Ingeniero en Tecnologías de la Información, y reúne los requisitos de fondo y forma para su sustentación.

Quito, Ecuador, xx de xx de 2026

Ing. Andrés Rubio Proaño, PhD.
LECTOR

Ing. Jaime Fabrizzio Peñafiel, MSc.
LECTOR

DEDICATORIA

(Obligatoria)
La dedicatoria va en la parte inferior derecha de la página.

AGRADECIMIENTO

(Obligatorio)
El agradecimiento va en la parte inferior derecha de la página.

Índice de Contenidos

CAPÍTULO I: Introducción **16**

1.1 Contextualización 16

1.1.1 Contexto macro: la exposición del sector educativo a nivel mundial 16

1.1.2 Contexto meso: América Latina y Ecuador 17

1.1.3 Contexto micro: las IES ecuatorianas y la unidad de análisis 19

1.2 Estado del Arte 20

1.2.1 Marcos de referencia para la evaluación de impacto y el riesgo de privacidad 20

1.2.2 Métodos de estimación del riesgo 23

1.2.3 Gestión de riesgos de seguridad de la información en el sector público y educativo 24

1.2.4 Protección de datos personales en instituciones de educación superior 24

1.2.5 Antecedentes latinoamericanos y ecuatorianos 25

1.2.6 Análisis comparativo y brecha identificada 26

1.3 Planteamiento del Problema 27

1.3.1 Análisis crítico 27

1.3.2 Prognosis 29

1.3.3 Formulación del problema 29

1.3.4 Preguntas directrices 29

1.3.5 Delimitación 29

1.4 Justificación 30

1.5 Objetivos 31

1.5.1 Objetivo General 31

1.5.2 Objetivos Específicos 31

1.6 Alcance del Proyecto 32

1.7 Fundamentación Teórica 33

CAPÍTULO II: Metodología **34**

2.1 Diagnóstico de la Situación Actual 34
2.2 Área de Estudio 34
2.3 Metodología de Desarrollo o Implementación 34
2.4 Técnicas e Instrumentos de Recolección de Información 35
2.5 Requerimientos del Proyecto 35
2.5.1 Requerimientos Funcionales 35
2.5.2 Requerimientos No Funcionales 35
2.6 Diseño de la Solución 35
2.7 Justificación Técnica 35
2.7.1 Ejemplo de Imagen 1 35
2.7.2 Ejemplo de Ecuación 1 36

CAPÍTULO III: Implementación, Pruebas y Resultados 37
3.1 Descripción de la Solución 37
3.2 Proceso de Implementación 37
3.3 Pruebas y Validación 37
3.4 Resultados 37
3.4.1 Ejemplo de Figura 2 37
3.4.2 Ejemplo de Tabla 2 38
3.4.3 Ejemplo de Imagen 2 38
3.4.4 Ejemplo de Ecuación 2 38
3.4.5 Ejemplos de Referencias Cruzadas 39
3.5 Cronograma y Presupuesto 39

CAPÍTULO IV: Conclusiones y Recomendaciones 40
4.1 Conclusiones 40
4.2 Recomendaciones 40
4.3 Trabajos Futuros 40

REFERENCIAS 41

GLOSARIO 48

ANEXO A: Título del Anexo A 49

Índice de Tablas

1 Trabajos relacionados con los marcos, la estimación y la gestión de riesgos (ejes 1 a 3). 21

2 Trabajos relacionados con la protección de datos personales en IES y antecedentes regionales (ejes 4 y 5). 22

3 Comparación de marcos y trabajos relacionados con los requisitos del proyecto. 26

4 Árbol de problemas: causas, problema central y efectos. 27

5 Área de estudio. 34

6 Ejemplo de tabla comparativa antes y después de la implementación. 38

Índice de Figuras

1 Árbol de problemas. 28

2 Ejemplo de figura para presentar resultados o arquitectura implementada. 38

Índice de Imágenes

1 Ejemplo de imagen para documentación visual de infraestructura o evidencias. 36

2 Ejemplo de imagen para evidenciar interfaz, panel o consola de operación. 39

Índice de Ecuaciones

1 Cálculo de disponibilidad del servicio 36
2 Cálculo porcentual de mejora obtenida 39

Índice de Anexos

Anexo A: Título del Anexo A 49

UNIVERSIDAD INDOAMÉRICA

FACULTAD DE INGENIERÍAS

INGENIERÍA EN TECNOLOGÍAS DE LA INFORMACIÓN

TEMA: METODOLOGÍA PARA EL DIAGNÓSTICO Y GESTIÓN DE RIESGOS EN EL TRATAMIENTO DE DATOS PERSONALES

AUTOR(A): Ramon Alejandro Manzaba Castro

TUTOR(A): Ing. Cristina Jiménez, MSc.

RESUMEN EJECUTIVO

[Redacte el resumen del Trabajo de Integración Curricular en un solo párrafo, con un máximo de 300 palabras. Exponga de manera clara el problema, el objetivo general, la metodología empleada, los principales resultados obtenidos y las conclusiones.]

DESCRIPTORES: *[Incluya de 3 a 4 palabras clave representativas, ordenadas alfabéticamente y separadas por comas.]*

UNIVERSIDAD INDOAMÉRICA

FACULTY OF ENGINEERING

BACHELOR'S DEGREE IN INFORMATION TECHNOLOGY ENGINEERING

TOPIC: METHODOLOGY FOR RISK DIAGNOSIS AND MANAGEMENT IN PERSONAL DATA PROCESSING

AUTHOR: Ramon Alejandro Manzaba Castro

ADVISOR: Ing. Cristina Jiménez, MSc.

ABSTRACT

[Write the English version of the executive summary in a single paragraph, with a maximum of 300 words. Clearly present the problem, general objective, methodology, main results, and conclusions.]

KEYWORDS: *[Include 3 to 4 representative keywords in alphabetical order, separated by commas.]*

CAPÍTULO I

INTRODUCCIÓN

El presente trabajo de integración curricular aborda el tema *Metodología para el diagnóstico y gestión de riesgos en el tratamiento de datos personales*, circunscrito a los datos personales de estudiantes y docentes que tratan las instituciones de educación superior (IES) ecuatorianas en el marco de la Ley Orgánica de Protección de Datos Personales (LOPDP).

1.1 Contextualización

1.1.1 Contexto macro: la exposición del sector educativo a nivel mundial

La educación superior se ha consolidado como uno de los sectores con mayor exposición a incidentes que comprometen datos personales. La edición 2024 del estudio *The State of Ransomware in Education*, basada en una encuesta a 5 000 responsables de tecnología de 14 países, de los cuales 600 pertenecían a organizaciones educativas, reportó que el 66 % de las IES había sufrido un ataque de *ransomware* en el último año, que el 77 % de esos ataques terminó con el cifrado de datos y que el costo medio de recuperación en el subsector alcanzó 4,02 millones de dólares [1]. Estas cifras ubican a las universidades por encima del promedio intersectorial y muestran que el problema no se limita a la disponibilidad de los sistemas, sino que afecta de forma directa la confidencialidad de los registros de estudiantes y docentes.

La literatura académica coincide en ese diagnóstico. La revisión de Ulven y Wangen [2] sintetizó los activos críticos, eventos de amenaza y vulnerabilidades frecuentes en la educación superior, concluyó en nueve riesgos estratégicos de ciberseguridad para el sector y advirtió que ya se han producido brechas de datos graves que probablemente se repetirán sin una gestión de riesgos adecuada; los autores señalan, además, que la investigación empírica sobre riesgos en este sector es escasa y presenta vacíos importantes. En la misma línea, Li et al. [3] partieron de que los entornos digitales universitarios, complejos y dinámicos, son altamente vulnerables a brechas de datos y, con una muestra de universidades chinas, encontraron que la divulgación pública de vulnerabilidades incrementa la frecuencia de brechas, mientras que la adopción de servicios en la nube la reduce; es decir, la ex-

posición depende de decisiones de gestión sobre vulnerabilidades y plataformas, lo que refuerza la necesidad de un enfoque de gestión de riesgos y no solo de controles técnicos puntuales.

El crecimiento de las plataformas digitales de aprendizaje amplía la superficie de tratamiento. Liu y Khalil [4], en una revisión sistemática sobre analítica del aprendizaje, identificaron ocho problemas interrelacionados de privacidad y protección de datos a lo largo del ciclo de vida de esos datos, desde la recolección hasta la explotación de resultados. Por su parte, Fernandes et al. [5] estudiaron la implementación del Reglamento General de Protección de Datos (RGPD) en universidades públicas portuguesas y determinaron dieciséis factores críticos de éxito, entre los que destacan el compromiso de la alta dirección y la cultura organizacional de protección de datos; su hallazgo sugiere que, incluso en jurisdicciones con larga tradición normativa, la adecuación de las IES depende más de la gestión que de la tecnología disponible.

1.1.2 Contexto meso: América Latina y Ecuador

En América Latina, los incidentes en universidades han pasado de ser casos aislados a eventos con consecuencias públicas visibles. En marzo de 2023, la Universidad Nacional de Colombia sufrió un ataque de *ransomware* que cifró parte de su información y obligó a aislar sus sistemas financiero, académico y de talento humano mientras se restablecían los servicios [6]. En octubre de 2024, la Universidad Técnica Federico Santa María, en Chile, registró un incidente atribuido al grupo RansomHub, tras el cual se publicaron en la *dark web* alrededor de 14 GB de información que incluía listados de estudiantes con su número de identificación, carrera y año de ingreso, así como datos de deudores del fondo de crédito estudiantil [7]. En el ámbito académico, Zappelini et al. [8] mostraron que, en Brasil, el uso de medios digitales para la docencia y la evaluación remota en IES plantea riesgos específicos cuando los titulares son adolescentes, situación análoga al régimen de categorías especiales que establece la normativa ecuatoriana.

Ecuador cuenta con un antecedente nacional que evidenció la magnitud del problema antes de la existencia de una ley específica. En septiembre de 2019 se reportó la exposición de una base de datos de una empresa privada de mercadeo y analítica que contenía información de alrededor de 20 millones de personas, incluidos cerca de 6,7 millones de niños, con campos como nombres, fecha de nacimiento, domicilio, teléfonos y nivel de educación [9]. Ese caso aceleró el debate legislativo que culminó con la expedición de la LOPDP, publicada en el Quinto Suplemento del Registro Oficial N.º 459 el 26 de mayo de 2021 [10]. Su reglamento

general fue expedido mediante el Decreto Ejecutivo N.º 904 y publicado en el Tercer Suplemento del Registro Oficial N.º 435 el 13 de noviembre de 2023 [11].

La LOPDP establece obligaciones que inciden directamente en la gestión de riesgos. El artículo 37 exige al responsable identificar la probabilidad de riesgos e implementar un proceso de verificación, evaluación y valoración continua de las medidas de seguridad; el artículo 40 obliga a utilizar una metodología de análisis de riesgos, amenazas y vulnerabilidades que considere las particularidades del tratamiento, de las partes involucradas y las categorías y volumen de datos; y el artículo 42 vuelve obligatoria la evaluación de impacto cuando exista tratamiento a gran escala de categorías especiales de datos [10, arts. 37, 40 y 42]. A ello se suma la obligación de notificar las vulneraciones de seguridad a la autoridad en el término de cinco días (art. 43). La Disposición Transitoria Primera difirió por dos años la vigencia del régimen sancionatorio, con lo que el periodo de adecuación concluyó en 2023 [10].

La Superintendencia de Protección de Datos Personales (SPDP) comenzó a emitir normativa técnica entre 2025 y 2026. Mediante la Resolución N.º SPDP-SPD-2025-0003-R, del 29 de abril de 2025, publicada en el Cuarto Suplemento del Registro Oficial N.º 41 el 19 de mayo de 2025, expidió la *Guía de Gestión de Riesgos y Evaluación de Impacto del Tratamiento de Datos Personales*, cuyo capítulo I es de cumplimiento obligatorio y cuyo capítulo II ofrece metodologías referenciales [12, 13]; posteriormente, mediante la Resolución N.º SPDP-SPD-2026-0012-R, publicada en el Suplemento del Registro Oficial N.º 254 el 30 de marzo de 2026, expidió la segunda versión (V.2) de la guía [14]. Asimismo, la Resolución N.º SPDP-SPD-2026-0005-R, publicada en el Suplemento del Registro Oficial N.º 231 el 25 de febrero de 2026, definió el Modelo Técnico de Gran Escala y estableció que constituyen tratamiento a gran escala, de forma directa, los tratamientos relativos a la salud y a otras categorías especiales, así como el tratamiento sistemático de datos de niñas, niños y adolescentes en entornos educativos; esa calificación vuelve obligatorias la evaluación de impacto previa y la designación de un delegado de protección de datos [15, arts. 12 y 14].

La autoridad ya ha ejercido su potestad sancionadora. El 1 de diciembre de 2025 se dieron a conocer las primeras sanciones por infracciones graves de la LOPDP, impuestas a la Liga Profesional de Fútbol del Ecuador y a la Federación Ecuatoriana de Fútbol por un total cercano a 454 500 dólares, con fundamento en el artículo 68 de la ley y por no implementar medidas administrativas, técnicas y físicas suficientes para garantizar un tratamiento adecuado [16, 17]. Aunque ninguno de esos casos corresponde a una IES, demuestran que las obligaciones de la ley son exigibles.

Debe subrayarse, además, que el mismo artículo 68 tipifica como infracción grave del responsable, en su numeral 4, no utilizar metodologías de análisis y gestión de riesgos adaptadas a la naturaleza de los datos personales, a las particularidades del tratamiento y a las partes involucradas [10, art. 68], de modo que la ausencia de una metodología constituye, por sí misma, una conducta sancionable. La aplicación de este régimen es reciente: hasta septiembre de 2025 la SPDP había recibido 191 denuncias sin haber impuesto sanción alguna, porque la ley prevé que ante una infracción grave se ordenen primero medidas correctivas y solo se sancione si estas no se cumplen [18]. En las fuentes públicas consultadas no se identificó, a la fecha de redacción, un procedimiento sancionador contra una IES, por lo que para estas instituciones el riesgo jurídico se mantiene latente y aún no se ha materializado.

1.1.3 Contexto micro: las IES ecuatorianas y la unidad de análisis

En el sistema de educación superior ecuatoriano, la evidencia disponible indica que la adecuación a la LOPDP es heterogénea. Álvarez-Carrión y Hernández-Sotomayor [19] analizaron la protección de datos en plataformas educativas digitales y concluyeron que, aunque la ley ofrece un marco sólido, su implementación enfrenta brechas de infraestructura y de capacitación en ciberseguridad; al revisar vulneraciones documentadas en universidades del país, identificaron los fallos técnicos y el error humano como causas principales. Piray Rodríguez et al. [20], mediante revisión documental y análisis normativo, encontraron diferencias marcadas entre instituciones en la adopción de políticas internas de protección de datos y observaron que solo un número limitado de universidades las aplica de manera destacada. A nivel de gestión de riesgos, López-Vasco et al. [21] documentaron la aplicación de ISO/IEC 27001 en institutos tecnológicos de educación superior del Ecuador, lo que constituye un antecedente de diagnóstico y planificación de controles en el sector, aunque centrado en la seguridad de la información y no en los derechos de los titulares.

La unidad de análisis de este trabajo se ubica en la Universidad Tecnológica Indoamérica (UTI), institución de educación superior particular con sede en Quito, cuya Facultad de Ingenierías propone el presente tema. Las IES tratan datos de estudiantes, aspirantes, graduados, docentes y personal administrativo en procesos como admisión y matrícula, registro de calificaciones, becas, bienestar estudiantil, aula virtual y titulación; varios de esos procesos involucran categorías especiales en los términos del artículo 25 de la LOPDP, como datos de salud, de discapacidad o de adolescentes que ingresan a la universidad [10, art. 25]. La unidad o proceso específico que servirá de caso de estudio se definirá con la tutoría, y toda información

institucional se tratará de forma anonimizada o agregada, sin datos personales reales ni identificación de funcionarios.

1.2 Estado del Arte

La revisión de antecedentes se realizó en bases de datos académicas (IEEE Xplore, ScienceDirect, SpringerLink, Scopus, SciELO y Google Académico) y en los sitios oficiales de autoridades de protección de datos y de organismos de normalización. Se priorizaron publicaciones de 2019 en adelante, sin excluir los trabajos seminales, y solo se incluyeron fuentes con DOI o con publicación oficial verificable. Los criterios de inclusión fueron tres: que el trabajo propusiera o evaluara un método de gestión de riesgos o de evaluación de impacto sobre datos personales, que abordara el tratamiento de datos en instituciones de educación superior, o que aportara evidencia normativa o empírica del contexto latinoamericano y ecuatoriano. Los trabajos seleccionados se organizaron en cinco ejes: (1) marcos de referencia para la evaluación de impacto y el riesgo de privacidad; (2) métodos de estimación del riesgo; (3) gestión de riesgos de seguridad de la información en el sector público y educativo; (4) protección de datos personales en IES, y (5) antecedentes latinoamericanos y ecuatorianos. Las Tablas 1 y 2 resumen los trabajos académicos analizados y la Tabla 3 compara los principales marcos metodológicos con los requisitos de este proyecto.

1.2.1 Marcos de referencia para la evaluación de impacto y el riesgo de privacidad

Los marcos normativos y de autoridades de control constituyen el primer referente para cualquier metodología. La norma ISO/IEC 29134:2023 ofrece directrices para el proceso de evaluación de impacto en la privacidad y para la estructura y el contenido del informe resultante, aplicables a organizaciones de cualquier tipo y tamaño [36]. En el ámbito iberoamericano, la Agencia Española de Protección de Datos (AEPD) publicó en 2021 una guía que unifica la gestión del riesgo y la evaluación de impacto, aplicable a cualquier tratamiento con independencia de su nivel de riesgo y que, para los tratamientos de alto riesgo, orienta la realización de la EIPD y la eventual consulta previa a la autoridad [37]. El NIST Privacy Framework, por su parte, es una herramienta voluntaria basada en riesgos y resultados, organizada en un núcleo, perfiles y niveles de implementación, que no está ligada a un sector ni a una jurisdicción concretos [38]. Para la valoración del impacto de una vulneración, ENISA propuso una metodología de severidad que combina el contexto

Tabla 1: Trabajos relacionados con los marcos, la estimación y la gestión de riesgos (ejes 1 a 3).

Eje	Trabajo	Enfoque y aporte	Limitación respecto de este proyecto
1	Deng et al. [22]	Marco LINDDUN de modelado de amenazas a la privacidad con siete categorías y árboles de amenaza.	Orientado al diseño de software; no estima probabilidad ni impacto.
1	Bieker et al. [23]	Proceso adaptable de EIPD derivado de los requisitos del RGPD.	Marco europeo; sin aplicación sectorial.
1	Vemou y Karyda [24]	Comparación de métodos PIA de autoridades, normas y academia; criterios de buenas prácticas.	Criterios generales, sin aplicación a un caso.
1	Wairimu et al. [25]	Revisión sistemática de metodologías PIA y PRA y de la forma en que se han evaluado.	No se centra en un sector ni en la normativa ecuatoriana.
1	Iwaya et al. [26]	*Scoping review* sobre la aplicación práctica de las PIA/EIPD, sus beneficios y dificultades.	Evidencia mayoritariamente europea; no aborda IES.
1	Wairimu et al. [27]	Percepción de profesionales sobre el uso de categorías de daño a la privacidad en la evaluación de riesgos.	No propone escalas de impacto aplicables a un sector.
2	Wang et al. [28]	Implementación del modelo FAIR mediante redes bayesianas para estimar frecuencia y magnitud de pérdidas.	Perspectiva financiera del responsable; no considera el daño a titulares.
3	Patiño et al. [29]	Metodología de gestión de riesgos TIC basada en ISO/IEC 27005 para entidades gubernamentales ecuatorianas.	Orientada a activos de información, no a derechos de titulares.
3	Ulven y Wangen [2]	Revisión sistemática de riesgos de ciberseguridad en educación superior; nueve riesgos estratégicos.	Identifica riesgos, pero no define un proceso de gestión.
3	Li et al. [3]	Factores que explican las brechas de datos en universidades chinas.	Análisis explicativo; no ofrece una metodología.
3	López-Vasco et al. [21]	Diagnóstico y plan de controles ISO/IEC 27001 en institutos tecnológicos de Ecuador.	Enfoque de seguridad de la información; no integra la LOPDP.

Elaborado por: Ramón Alejandro Manzaba Castro
Fuente: Elaboración propia a partir de las fuentes citadas

Tabla 2: Trabajos relacionados con la protección de datos personales en IES y antecedentes regionales (ejes 4 y 5).

Eje	Trabajo	Enfoque y aporte	Limitación respecto de este proyecto
4	Gursoy et al. [30]	Técnicas de anonimización y privacidad diferencial para analítica del aprendizaje.	Controles técnicos aislados de un proceso de riesgos.
4	Habbabeh et al. [31]	Instrumento de 44 controles para medir la alineación de una IES con el RGPD.	Mide cumplimiento, no riesgo; no distingue riesgo inherente y residual.
4	Vanezi et al. [32]	Cumplimiento del RGPD desde el diseño en una plataforma de *e-learning*.	Limitado a una plataforma; no abarca la institución.
4	Tsai et al. [33]	Expectativas y conductas de privacidad de estudiantes frente a la analítica del aprendizaje.	Estudio de percepción; no evalúa riesgos.
4	Fernandes et al. [5]	Factores críticos de éxito para implementar el RGPD en universidades públicas.	Marco europeo; no propone una metodología de riesgos.
4	Liu y Khalil [4]	Revisión sistemática de problemas de privacidad en el ciclo de vida de la analítica del aprendizaje.	Catálogo de problemas, sin valoración del riesgo.
4	Maguraushe et al. [34]	Encuesta diagnóstica de conciencia, expectativas y confianza de estudiantes sobre privacidad.	Diagnóstico de percepción; no cubre procesos ni controles.
5	Guerrero Argote [35]	Adopción de *e-proctoring* y riesgos para la privacidad en universidades de Argentina, Chile y Perú.	Estudio exploratorio; análisis jurídico preliminar.
5	Zappelini et al. [8]	Datos de adolescentes en IES brasileñas bajo la LGPD; docencia y evaluación remota.	Análisis jurídico; sin método de riesgos.
5	Álvarez-Carrión y Hernández-Sotomayor [19]	Protección de datos en plataformas educativas de IES ecuatorianas.	Diagnóstico normativo; no define un proceso de gestión de riesgos.
5	Piray Rodríguez et al. [20]	Garantías de privacidad y políticas internas en IES ecuatorianas.	Revisión documental; sin aplicación de un método de riesgos.

Elaborado por: Ramón Alejandro Manzaba Castro
Fuente: Elaboración propia a partir de las fuentes citadas

del tratamiento, la facilidad de identificación de los titulares y las circunstancias de la vulneración [39], criterios que resultan útiles para graduar el impacto sobre los titulares.

Desde la academia, LINDDUN aporta un marco sistemático para identificar amenazas a la privacidad a partir de un modelo de flujos de información del sistema, con siete categorías —vinculabilidad, identificabilidad, no repudio, detectabilidad, divulgación de información, desconocimiento e incumplimiento— y catálogos de árboles de amenaza asociados a tecnologías de mejora de la privacidad [22]. Bieker et al. [23] analizaron las disposiciones del RGPD sobre la EIPD y propusieron un proceso adaptable que integra los requisitos ya establecidos con los nuevos de la regulación. Las revisiones posteriores matizan la madurez de este campo: Wairimu et al. [25] muestran que existe una amplia variedad de metodologías PIA y PRA, pero que su validación empírica es limitada y heterogénea, lo que dificulta elegir una de ellas sin adaptación; Iwaya et al. [26], tras sintetizar 45 estudios sobre evaluaciones de impacto aplicadas en organizaciones reales, constatan que aún falta evidencia empírica sobre su adopción y efectividad; y Vemou y Karyda [24] proponen criterios para valorar la calidad de un método PIA, útiles como referencia para evaluar la metodología que este trabajo diseñe. Finalmente, Wairimu et al. [27] concluyen que las categorías de daño a la privacidad son un complemento crítico de las metodologías PIA, EIPD y PRA, aunque recomiendan priorizarlas para distribuir adecuadamente el tiempo y los recursos de la evaluación; este hallazgo respalda la definición de escalas de impacto centradas en el titular.

1.2.2 Métodos de estimación del riesgo

La forma de estimar la probabilidad y el impacto es uno de los puntos más débiles de las metodologías de uso corriente. La mayoría de marcos emplea escalas ordinales y matrices de calor, mientras que los enfoques cuantitativos, como el modelo FAIR, estiman la frecuencia y la magnitud de las pérdidas; Wang et al. [28] implementaron y ampliaron FAIR mediante redes bayesianas, lo que permite incorporar dependencias causales y actualizar las estimaciones con nueva evidencia. La segunda versión de la guía de la SPDP recoge esta discusión y fija reglas que condicionan el diseño de la metodología: toda estimación de probabilidad o impacto debe acompañarse de su justificación (*rationale*); una escala de 1 a 3 o de 1 a 5 no constituye un análisis cuantitativo, sino un conjunto de etiquetas; las matrices de calor sirven para representar el riesgo, no para calibrarlo; la probabilidad debe referirse a un lapso definido, y la confidencialidad, la integridad y la disponibilidad deben modelarse por separado [14]. Cuando no se dispone de datos históricos suficientes, la guía

admite la opinión de expertos calibrada, por ejemplo mediante el método Delphi, y su validación con métricas como el *Brier score* [14]. Ninguno de los trabajos aplicados al sector educativo revisados incorpora estas exigencias.

1.2.3 Gestión de riesgos de seguridad de la información en el sector público y educativo

Patiño et al. [29] constituyen el antecedente ecuatoriano más directo de adaptación de ISO/IEC 27005 a un contexto institucional, mediante una guía por pasos para entidades del sector público. López-Vasco et al. [21] trasladan ese tipo de enfoque a la educación superior tecnológica, con un diagnóstico y un plan de controles basados en ISO/IEC 27001. En el plano internacional, la revisión de Ulven y Wangen [2] sintetiza los activos críticos, las amenazas y las vulnerabilidades más frecuentes en universidades y concluye en nueve riesgos estratégicos, mientras que Li et al. [3] identifican factores organizacionales que explican la ocurrencia de brechas de datos en universidades, como la divulgación de vulnerabilidades y el uso de servicios en la nube. Estos trabajos proporcionan catálogos de amenazas y evidencia útil para estimar la probabilidad, pero valoran el riesgo desde la perspectiva de los activos de la organización y no desde el daño a los titulares, que es el eje de la LOPDP y de la guía de la SPDP.

1.2.4 Protección de datos personales en instituciones de educación superior

Un conjunto de estudios aborda la protección de datos en las IES desde el cumplimiento normativo. Habbabeh et al. [31] constataron que la literatura ofrecía escasa orientación para que las universidades verificaran su cumplimiento del RGPD y, siguiendo los lineamientos de la ciencia del diseño, construyeron un instrumento de 44 controles cuya puntuación total indica el grado de alineación de la institución con el reglamento y que puede emplearse como herramienta de gestión para el seguimiento de medidas. Fernandes et al. [5] identificaron dieciséis factores críticos de éxito para implementar el RGPD en universidades públicas portuguesas, entre ellos el compromiso de la alta dirección y la cultura de protección de datos. Vanezi et al. [32] documentaron la incorporación de requisitos del RGPD desde el diseño en una plataforma de aprendizaje en línea.

Otro grupo de trabajos se concentra en los tratamientos derivados de la analítica del aprendizaje. Gursoy et al. [30] examinaron técnicas de anonimización y de privacidad diferencial aplicadas a datos educativos; Tsai et al. [33] analizaron la brecha entre las expectativas de privacidad de los estudiantes y su conducta efectiva, con énfasis en la transparencia y la confianza; y Liu y Khalil [4] identificaron ocho

problemas interrelacionados de privacidad a lo largo del ciclo de vida de esos datos. Desde la perspectiva de los titulares, Maguraushe et al. [34] aplicaron una encuesta diagnóstica sobre conciencia, expectativas y confianza de los estudiantes en materia de privacidad en el sector de educación superior de un país en desarrollo, instrumento que puede adaptarse a la fase de diagnóstico. En conjunto, estos estudios aportan controles, factores de éxito e instrumentos de medición, pero miden el cumplimiento o la percepción y no el riesgo, por lo que no distinguen entre riesgo inherente y residual ni priorizan el tratamiento.

1.2.5 Antecedentes latinoamericanos y ecuatorianos

En América Latina, Guerrero Argote [35] mapeó 267 universidades de Argentina, Chile y Perú y encontró que 46 utilizaban *software* de supervisión remota de exámenes (*e-proctoring*), con mayor adopción en las universidades privadas; ocho de los nueve productos identificados incorporaban reconocimiento facial y trataban imágenes, voz, rasgos faciales y datos de navegación, y el autor reportó un bajo cumplimiento de las obligaciones de registro de bases de datos. Zappelini et al. [8] mostraron que, en Brasil, el uso de medios digitales para la docencia y la evaluación remota plantea riesgos específicos cuando los titulares son adolescentes. En Colombia, la Superintendencia de Industria y Comercio presentó en 2026 una guía sobre el tratamiento de datos personales en el contexto universitario, que recuerda que las IES son responsables del tratamiento de los datos de su comunidad, exige separar las finalidades necesarias para el servicio educativo de las opcionales y recomienda designar un oficial de protección de datos y reforzar la seguridad de la información sensible [40]. Estos antecedentes confirman que los riesgos identificados en Europa se reproducen en la región, con el agravante de marcos de control aún en consolidación.

En Ecuador, Álvarez-Carrión y Hernández-Sotomayor [19] concluyeron que la LOPDP ofrece un marco sólido, pero que su implementación en plataformas educativas enfrenta brechas de infraestructura y de capacitación, con fallos técnicos y error humano como causas principales de las vulneraciones documentadas; Piray Rodríguez et al. [20] observaron una adopción desigual de políticas internas de protección de datos entre universidades. La normativa técnica de la SPDP —la guía de gestión de riesgos en sus dos versiones y la norma de gran escala— es posterior a la mayoría de estos estudios [12, 14, 15], por lo que ningún antecedente nacional la ha incorporado todavía.

1.2.6 Análisis comparativo y brecha identificada

La Tabla 3 contrasta los marcos y trabajos más cercanos con seis criterios que se derivan de la LOPDP y de la guía de la SPDP: la valoración del riesgo desde la perspectiva de los titulares; la cobertura del ciclo completo de gestión (contexto, identificación, análisis, evaluación y tratamiento); la integración de la EIPD; la exigencia de estimaciones justificadas; la aplicación al sector de la educación superior, y la alineación con la normativa ecuatoriana.

Tabla 3: Comparación de marcos y trabajos relacionados con los requisitos del proyecto.

Marco o trabajo	Enfoque titulares	Ciclo completo	EIPD	Estimación justificada	Sector IES	Normativa Ecuador
ISO/IEC 27005:2022 [41]	No	Sí	No	Parcial	No	No
ISO/IEC 29134:2023 [36]	Sí	Parcial	Sí	No	No	No
AEPD (2021) [37]	Sí	Sí	Sí	Parcial	No	No
NIST Privacy Framework [38]	Sí	Parcial	No	No	No	No
LINDDUN [22]	Sí	Parcial	No	No	No	No
FAIR bayesiano [28]	No	Parcial	No	Sí	No	No
Guía SPDP V.2 [14]	Sí	Sí	Sí	Sí	No	Sí
Patiño et al. [29]	No	Sí	No	No	No	Sí
López-Vasco et al. [21]	No	Parcial	No	No	Sí	Sí
Habbabeh et al. [31]	Parcial	No	No	No	Sí	No
Metodología propuesta	**Sí**	**Sí**	**Sí**	**Sí**	**Sí**	**Sí**

Elaborado por: Ramón Alejandro Manzaba Castro
Fuente: Elaboración propia a partir de las fuentes citadas

La comparación muestra que ningún marco ni trabajo revisado satisface a la vez los seis criterios. Los marcos internacionales de privacidad adoptan la perspectiva de los titulares, pero no responden a la normativa ecuatoriana ni a las particularidades de una IES; los modelos de seguridad de la información aplicados en el país cubren el ciclo de gestión, pero sobre activos de la organización; los estudios sectoriales miden el cumplimiento o la percepción, no el riesgo; y la guía de la SPDP, aunque fija el marco obligatorio, es deliberadamente general y no ofrece una aplicación al sector educativo. El vacío que se identifica, por tanto, es la ausencia de una metodología que integre la evaluación de riesgos sobre los derechos de los titulares, las obligaciones de la LOPDP y de su reglamento, y las etapas y reglas de estimación definidas por la SPDP en el contexto específico de una IES ecuatoriana. Este trabajo se orienta a cubrir ese vacío.

1.3 Planteamiento del Problema

Las IES tratan grandes volúmenes de datos personales académicos, administrativos y de salud sin contar necesariamente con procesos sistemáticos de diagnóstico y gestión de riesgos alineados a la LOPDP, lo que genera exposición legal y vulnerabilidad de la información. La normativa exige una metodología de análisis de riesgos y, en los casos de tratamiento a gran escala de categorías especiales, una evaluación de impacto previa [10, 15]; no obstante, la evidencia nacional muestra una adopción desigual de políticas y brechas de capacidad técnica y humana en las universidades [19, 20].

1.3.1 Análisis crítico

El análisis del problema se estructuró mediante un árbol de problemas que relaciona sus causas con el problema central y con los efectos que produce. La Tabla 4 presenta esa relación y la Figura 1 la representa de forma gráfica.

Tabla 4: Árbol de problemas: causas, problema central y efectos.

Causas	**Problema central**	**Efectos**
C1. Ausencia de un inventario o registro de actividades de tratamiento que identifique procesos, datos y titulares.	**Las IES tratan grandes volúmenes de datos personales sin procesos sistemáticos de diagnóstico y gestión de riesgos alineados a la LOPDP, lo que genera exposición legal y vulnerabilidad de la información.**	E1. Exposición a sanciones por infracciones graves (arts. 68 y 72 de la LOPDP).
C2. Enfoque de seguridad centrado en activos tecnológicos y no en los derechos de los titulares.		E2. Vulnerabilidad de la información ante incidentes de confidencialidad, integridad y disponibilidad.
C3. Desconocimiento de la normativa técnica reciente de la SPDP (guía de riesgos, gran escala).		E3. Evaluaciones de impacto omitidas o realizadas sin las etapas previas exigidas.
C4. Brechas de capacitación y cultura de protección de datos en el personal.		E4. Incapacidad de notificar vulneraciones dentro del término legal de cinco días.
C5. Uso creciente de plataformas en la nube y servicios de terceros sin evaluación de riesgos.		E5. Pérdida de confianza de estudiantes y docentes y daño reputacional.

Elaborado por: Ramón Alejandro Manzaba Castro
Fuente: Elaboración propia con base en [10, 15, 19, 2]

La primera causa es la falta de un inventario de tratamientos. Sin conocer qué procesos tratan datos, qué categorías intervienen y cuántos titulares se ven afectados,

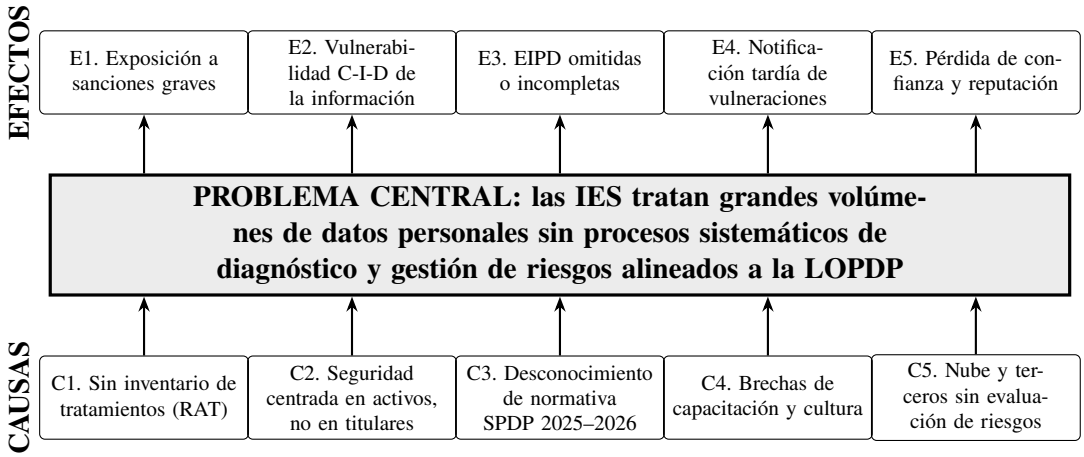


Figura 1: Árbol de problemas.
Elaborado por: Ramón Alejandro Manzaba Castro
Fuente: Elaboración propia

no es posible aplicar los criterios del artículo 40 de la LOPDP ni calcular si un tratamiento alcanza el umbral de gran escala definido por la SPDP [15]. La segunda causa es de enfoque: los modelos aplicados en el sector, como los descritos por Patiño et al. [29] y López-Vasco et al. [21], valoran el riesgo sobre los activos de la organización, mientras que la LOPDP pone en el centro los derechos y libertades de los titulares. La tercera causa obedece a la velocidad del cambio normativo, pues entre 2025 y 2026 la SPDP expidió la guía de riesgos, su segunda versión y la norma de gran escala, lo que supone una carga de actualización para las IES. La cuarta causa, vinculada al factor humano, coincide con el hallazgo de Álvarez-Carrión y Hernández-Sotomayor [19] sobre el peso del error humano en los incidentes de universidades ecuatorianas y con la relevancia que Fernandes et al. [5] asignan a la capacitación y a la cultura de protección de datos. La quinta causa responde a la migración de servicios académicos hacia plataformas de terceros, en las que la IES sigue siendo responsable del tratamiento.

Entre los efectos destaca la exposición legal, que en este caso es directa: carecer de una metodología de análisis y gestión de riesgos ya configura la infracción grave del artículo 68, numeral 4. Para una IES particular, las infracciones graves se sancionan con multas de entre el 0,7 % y el 1 % de su volumen de negocio del ejercicio anterior [10, art. 72], y las primeras sanciones impuestas por la SPDP demuestran que la autoridad ya aplica ese régimen [16]. A ello se suman la vulnerabilidad técnica, con la consecuente afectación a titulares, y la incapacidad de responder a tiempo ante una vulneración, dado que el plazo de notificación es breve y presupone que la institución ha identificado de antemano sus escenarios de riesgo.

1.3.2 Prognosis

De no abordarse el problema, las IES continuarían tratando datos de estudiantes y docentes sin conocer con certeza cuáles de sus tratamientos son de alto riesgo ni cuáles exigen una evaluación de impacto previa, con lo que quedarían en situación de incumplimiento frente a los artículos 40 y 42 de la LOPDP y a la Resolución SPDP-SPD-2026-0005-R. En un escenario de incidente, la ausencia de escenarios de riesgo y de un procedimiento de respuesta dificultaría cumplir el término de notificación de cinco días del artículo 43, lo que agravaría la responsabilidad de la institución. La tendencia regional de ataques contra universidades [7, 6, 1] permite prever que la probabilidad de un incidente no disminuirá por sí sola, y la actividad sancionadora de la SPDP [16] indica que las consecuencias jurídicas de no gestionar el riesgo serán cada vez más tangibles. En el plano institucional, cada unidad seguiría aplicando criterios propios y no comparables, lo que impediría priorizar inversiones en controles y demostrar responsabilidad proactiva ante la autoridad.

1.3.3 Formulación del problema

¿Cómo diagnosticar y gestionar de forma sistemática los riesgos del tratamiento de datos personales de estudiantes y docentes en una institución de educación superior, de modo que se cumplan las exigencias de la LOPDP y de la normativa técnica de la SPDP?

1.3.4 Preguntas directrices

La investigación se orienta mediante cinco preguntas directrices, cada una vinculada a un objetivo específico (OE). ¿Cuáles son los procesos actuales de tratamiento de datos personales en la institución o unidad seleccionada y en qué condiciones se ejecutan? (OE1). ¿Qué fases, actividades y criterios debe contener una metodología de identificación, evaluación, mitigación y monitoreo de riesgos alineada a la LOPDP y a la guía de la SPDP? (OE2). ¿Qué resultados se obtienen al aplicar la metodología en un caso de estudio real o simulado dentro de la institución? (OE3). ¿Qué riesgos inherentes y residuales se identifican y cómo se priorizan en una matriz derivada de esa aplicación? (OE4). ¿Qué recomendaciones de mejora continua permiten a la institución mantener la gestión de riesgos alineada a la LOPDP? (OE5).

1.3.5 Delimitación

En cuanto al contenido, el estudio pertenece al campo de las tecnologías de la información, en el área de gobernanza y seguridad de la información, y se centra

en la gestión de riesgos sobre el tratamiento de datos personales de estudiantes y docentes conforme a la LOPDP, su reglamento y la normativa técnica de la SPDP. En lo espacial, se desarrolla en la Universidad Tecnológica Indoamérica, sede Quito, en la unidad o proceso que se acuerde con la tutoría. En lo temporal, se ejecuta durante el periodo académico B26, con una duración prevista de seis meses de dedicación completa, y considera la normativa vigente hasta la fecha de cierre del trabajo.

1.4 Justificación

La importancia del trabajo radica en que la gestión de riesgos ha dejado de ser una buena práctica opcional para convertirse en una obligación jurídica. La LOPDP exige al responsable una metodología de análisis de riesgos y un proceso de evaluación continua de sus medidas de seguridad [10, arts. 37 y 40], y la SPDP ha concretado esa exigencia mediante una guía con un capítulo de cumplimiento obligatorio [12] y una norma que califica directamente como de gran escala los tratamientos de datos de salud y de adolescentes en entornos educativos [15]. Las IES, que tratan estos datos de forma habitual, requieren una herramienta que traduzca esas obligaciones a su realidad operativa.

La novedad del aporte reside en la integración de elementos que la literatura aborda por separado. Los antecedentes revisados ofrecen metodologías generales de evaluación de impacto [26, 25] o modelos de seguridad de la información centrados en activos [21, 29], pero no una metodología específica para IES ecuatorianas que adopte la perspectiva de los titulares exigida por la LOPDP y siga las etapas de la guía de la SPDP. Este vacío coincide con la escasez de investigación empírica sobre riesgos en la educación superior señalada por Ulven y Wangen [2].

La utilidad del proyecto se expresa en sus productos: un documento metodológico por fases y una matriz de riesgos aplicada, concebida como plantilla reutilizable en hoja de cálculo, que la institución podrá emplear para priorizar controles, documentar su responsabilidad proactiva y preparar evaluaciones de impacto. La factibilidad es técnica, operativa y económica, porque el trabajo se apoya en normas de acceso público, en herramientas ofimáticas de uso común y en el acceso a información institucional bajo las debidas autorizaciones, sin requerir infraestructura adicional.

Los beneficiarios directos son la institución, en su calidad de responsable del tratamiento, y las unidades académicas y administrativas que intervienen en el caso de estudio; los beneficiarios indirectos son los estudiantes y docentes, cuyos derechos se protegen mejor cuando los riesgos se identifican y tratan de forma anticipada, así como otras IES que podrán replicar la metodología. El impacto esperado es la

reducción de la exposición legal y de la vulnerabilidad de la información, junto con una mejora de la confianza de la comunidad universitaria.

El trabajo se inscribe en la línea de investigación Gestión de la Información, sublínea Gobernanza y seguridad de la información, y en el eje de aplicación Tecnologías para la educación. Asimismo, contribuye a las competencias del perfil de egreso PE-CP-06, que consiste en evaluar proyectos de TI en el ámbito de las buenas prácticas y en concordancia con el marco legal vigente; PE-MI-04, relativa a gestionar proyectos de TI aplicando conceptos éticos, legales, económicos y financieros para la toma de decisiones; PE-IS-04, referida a realizar proyectos de investigación sobre problemas técnicos de la profesión siguiendo una metodología científica; y PE-PP-05, que corresponde a implementar sistemas de seguridad informática bajo políticas organizacionales y estándares aceptados, con ética y responsabilidad.

1.5 Objetivos

1.5.1 Objetivo General

Diseñar una metodología de diagnóstico y gestión de riesgos para el tratamiento de datos personales de estudiantes y docentes en instituciones de educación superior, mediante la integración de las etapas de la guía de gestión de riesgos y evaluación de impacto de la SPDP con la norma ISO/IEC 27005:2022, para contribuir al cumplimiento de las obligaciones de análisis de riesgos y evaluación de impacto establecidas en la Ley Orgánica de Protección de Datos Personales (2021) y en su Reglamento General (2023).

1.5.2 Objetivos Específicos

1. Diagnosticar los procesos actuales de tratamiento de datos personales en la unidad seleccionada de la institución, mediante revisión documental, entrevistas a actores clave y un cuestionario de madurez, para establecer la línea base de cumplimiento respecto de la LOPDP (2021) y su Reglamento General (2023).

2. Diseñar las fases de la metodología —identificación, evaluación, mitigación y monitoreo de riesgos—, mediante la adaptación de las etapas de la guía de la SPDP y de la norma ISO/IEC 27005:2022, para orientar a la institución en un proceso sistemático, documentado y centrado en los derechos de los titulares.

3. Aplicar la metodología en un caso de estudio real o simulado dentro de la

institución, mediante la identificación y el análisis de escenarios de riesgo con criterio de expertos, para comprobar su aplicabilidad en el tratamiento de datos de estudiantes y docentes.

4. Elaborar una matriz de riesgos inherentes y residuales derivada del caso de estudio, mediante criterios de probabilidad e impacto justificados en una plantilla reutilizable de hoja de cálculo, para priorizar el tratamiento de los riesgos y sustentar la evaluación de impacto prevista en el artículo 42 de la LOPDP.

5. Formular recomendaciones de mejora continua, mediante la validación de los resultados con actores institucionales, para mantener la gestión de riesgos alineada a la LOPDP (2021), a su Reglamento General (2023) y a la normativa técnica de la SPDP.

1.6 Alcance del Proyecto

El alcance del proyecto comprende la revisión de los procesos actuales de tratamiento de datos personales en la institución o unidad seleccionada; el diseño de una metodología con fases de identificación, evaluación, mitigación y monitoreo de riesgos, precedidas por una fase de diagnóstico de madurez y articuladas con las etapas de la guía de la SPDP; la aplicación de la metodología en un caso de estudio real o simulado dentro de la institución; la generación de una matriz de riesgos inherentes y residuales en una plantilla reutilizable; y la formulación de recomendaciones de mejora continua alineadas a la LOPDP. La metodología se validará con actores institucionales mediante criterio de expertos.

El proyecto excluye de manera expresa tres aspectos. En primer lugar, no incluye la certificación legal formal ante la autoridad de protección de datos, por lo que sus resultados no constituyen una declaración de cumplimiento ante la SPDP. En segundo lugar, no cubre la implementación completa de todas las medidas correctivas recomendadas, que corresponderá a la institución según sus prioridades y recursos. En tercer lugar, no abarca una auditoría externa independiente; las revisiones que se realicen tendrán carácter interno y académico.

Entre las limitaciones se reconoce, primero, que el acceso a información institucional depende de las autorizaciones que se obtengan, razón por la cual el caso de estudio podrá ser simulado y toda evidencia se tratará de forma anonimizada o agregada. Segundo, la estimación de probabilidades e impactos se apoyará en criterio de expertos, con la incertidumbre propia de ese tipo de juicio, aunque cada valor

se acompañará de su justificación conforme exige la guía de la SPDP. Tercero, la normativa técnica de la SPDP se encuentra en evolución, por lo que la metodología se ajustará a la vigente a la fecha de cierre del trabajo.

1.7 Fundamentación Teórica

Un dato personal es aquel que identifica o hace identificable a una persona natural, y el tratamiento comprende cualquier operación realizada sobre esos datos, desde su recolección hasta su eliminación [10, art. 4]. La LOPDP distingue al responsable, que decide sobre la finalidad y el tratamiento, del encargado, que trata datos por cuenta de aquel, y reconoce categorías especiales que requieren protección reforzada: datos sensibles, datos de niñas, niños y adolescentes, datos de salud y datos de personas con discapacidad (art. 25). En una IES, la institución actúa como responsable y los proveedores de plataformas académicas suelen actuar como encargados.

La gestión de riesgos se entiende como el conjunto de actividades coordinadas para dirigir y controlar una organización con respecto al riesgo [42]. La norma ISO/IEC 27005:2022 desarrolla ese marco para la seguridad de la información mediante un proceso que comprende el establecimiento del contexto, la identificación, el análisis, la evaluación y el tratamiento de riesgos, junto con su comunicación y seguimiento [41]; la guía de la SPDP adopta esas mismas etapas y las orienta hacia la protección de los derechos de los titulares [12]. La norma ISO/IEC 27701:2025 complementa el enfoque con requisitos para un sistema de gestión de la información de privacidad [43].

La evaluación de impacto relativa a la protección de datos (EIPD) es el análisis previo de un tratamiento que probablemente conlleve un alto riesgo para los derechos y libertades de los titulares [10, art. 42]. La literatura la distingue del análisis de riesgos de seguridad porque su objeto es el daño a las personas y no la pérdida para la organización [25]. En cuanto a la estimación del riesgo, coexisten enfoques cualitativos, basados en escalas y criterio de expertos, y enfoques cuantitativos como el modelo FAIR, que estima la frecuencia y la magnitud de las pérdidas mediante simulación y redes bayesianas [28]. Distinguir entre riesgo inherente, previo a los controles, y riesgo residual, posterior a ellos, permite medir el efecto de las medidas propuestas, que es precisamente lo que el artículo 37 de la LOPDP exige evidenciar. Estos conceptos se desarrollarán con mayor profundidad en el marco de la metodología propuesta.

CAPÍTULO II

METODOLOGÍA

2.1 Diagnóstico de la Situación Actual

[Analizar el estado inicial del sistema, proceso o infraestructura antes de la implementación del proyecto. Describir cómo funciona actualmente y las principales limitaciones técnicas.]

2.2 Área de Estudio

Tabla 5: Área de estudio.

Dominio:	*[Indique el dominio académico o científico del proyecto.]*
Línea de investigación:	Gestión de la información
Sublínea de investigación:	Gobernanza y seguridad de la información.
Campo:	Tecnologías de la información y la comunicación (TIC)
Área:	*[Defina el área técnica específica del proyecto.]*
Aspectos:	*[Describa los procesos, tecnologías o problemas que serán analizados.]*
Objeto de estudio:	*[Indique la organización, sistema, proceso o infraestructura objeto del estudio.]*
Periodo de estudio:	*[Indique las fechas o el intervalo de tiempo que comprende el estudio.]*

2.3 Metodología de Desarrollo o Implementación

[Describir y justificar la metodología empleada según la naturaleza del proyecto, indicando las fases y actividades a ejecutar. Por ejemplo, metodologías ágiles o tradicionales para software, o modelos de diseño, implementación o despliegue

para hardware o infraestructura.]

2.4 Técnicas e Instrumentos de Recolección de Información

[Describir las técnicas utilizadas para obtener información durante el diagnóstico y la validación del proyecto, tales como entrevistas, encuestas u observación directa.]

2.5 Requerimientos del Proyecto

2.5.1 Requerimientos Funcionales

[Enumerar y describir los requerimientos funcionales que la solución debe cumplir.]

2.5.2 Requerimientos No Funcionales

[Describir requerimientos relacionados con seguridad, rendimiento, disponibilidad, escalabilidad u otros aplicables.]

2.6 Diseño de la Solución

[Describir el diseño técnico de la solución propuesta. Puede incluir arquitectura del sistema o infraestructura, diagramas lógicos y físicos, modelos de datos, componentes o configuraciones técnicas.]

2.7 Justificación Técnica

[Argumentar técnicamente la selección de tecnologías, herramientas, plataformas, equipos o servicios utilizados en el proyecto.]

Ejemplo de cita metodológica: la justificación de decisiones técnicas puede apoyarse en literatura de diseño e implementación de sistemas como [44, 45].

2.7.1 Ejemplo de Imagen 1

Ejemplo de referencia en el cuerpo del texto: la Imagen 1 puede usarse para documentar evidencia técnica del entorno, componentes o interfaz.
Elaborado por: Estudiante
Fuente: Captura referencial del proyecto



Imagen 1: Ejemplo de imagen para documentación visual de infraestructura o evidencias.

2.7.2 Ejemplo de Ecuación 1

Otro ejemplo de referencia: la Ecuación 1 muestra un cálculo típico para validación de disponibilidad del servicio.

$$Disponibilidad\ (\%) = \frac{T_{operativo}}{T_{total}} \times 100 \tag{1}$$

CAPÍTULO III

IMPLEMENTACIÓN, PRUEBAS Y RESULTADOS

3.1 Descripción de la Solución

[Presentar detalladamente la solución implementada, indicando los componentes desarrollados, configurados o integrados.]

3.2 Proceso de Implementación

[Describir paso a paso la ejecución técnica del proyecto, incluyendo desarrollo o configuración, integración de componentes y despliegue en un entorno real o controlado.]

3.3 Pruebas y Validación

[Describir las pruebas realizadas para validar el funcionamiento de la solución, tales como pruebas funcionales, integrales, de seguridad, rendimiento o conectividad, según aplique.]

3.4 Resultados

[Presentar los resultados obtenidos durante la validación, comparando la situación inicial con la posterior a la implementación. Incluir métricas, indicadores o evidencias.]

3.4.1 Ejemplo de Figura 2

Como ejemplo de mención con referencia: en la Figura 2 se observa una salida visual que puede emplearse para documentar arquitectura o resultados.
Elaborado por: Estudiante
Fuente: Elaboración propia



Figura 2: Ejemplo de figura para presentar resultados o arquitectura implementada.

3.4.2 Ejemplo de Tabla 2

Como ejemplo de mención con referencia: la Tabla 6 muestra una comparación antes/después para análisis cuantitativo.

Tabla 6: Ejemplo de tabla comparativa antes y después de la implementación.

Métrica	Antes	Después
Tiempo de respuesta (ms)	850	320
Disponibilidad (%)	96.2	99.3
Tasa de error (%)	4.8	1.2

Elaborado por: Estudiante
Fuente: Resultados de pruebas funcionales

3.4.3 Ejemplo de Imagen 2

Como ejemplo de referencia narrativa: la Imagen 2 permite incorporar evidencias de interfaz o panel operativo.
Elaborado por: Estudiante
Fuente: Evidencia del entorno de prueba

3.4.4 Ejemplo de Ecuación 2

Ejemplo de referencia a ecuación: la Ecuación 2 calcula el porcentaje de mejora de una métrica respecto al valor inicial.



Imagen 2: Ejemplo de imagen para evidenciar interfaz, panel o consola de operación.

$$Mejora\ (\%) = \frac{Valor_{antes} - Valor_{despues}}{Valor_{antes}} \times 100 \tag{2}$$

3.4.5 Ejemplos de Referencias Cruzadas

Ejemplo 1 de referencia cruzada entre capítulos: el análisis base se desarrolla en el Capítulo I, mientras que el enfoque metodológico se detalla en el Capítulo II.

Ejemplo 2 de referencia cruzada entre elementos: para relacionar diseño y validación se puede enlazar el apartado *Diseño de la Solución* (Capítulo II) con la Tabla 6, la Imagen 1 y la Ecuación 1.

3.5 Cronograma y Presupuesto

[Presentar la planificación de las fases de ejecución del proyecto y el detalle de los costos asociados a hardware, licencias, servicios u otros recursos.]

CAPÍTULO IV

CONCLUSIONES Y RECOMENDACIONES

4.1 Conclusiones

[Redactar conclusiones basadas en los resultados obtenidos y en el cumplimiento de los objetivos planteados.]

4.2 Recomendaciones

[Proponer mejoras, optimizaciones o ampliaciones del proyecto, fundamentadas en el análisis realizado.]

4.3 Trabajos Futuros

[Plantear líneas de desarrollo o investigación que puedan derivarse del proyecto implementado.]

[Incluya todas las referencias bibliográficas utilizadas en el documento. Deben estar citadas según normas IEEE y gestionadas mediante un gestor bibliográfico como Mendeley o Zotero.]

BIBLIOGRAFÍA

[1] Sophos, "The state of ransomware in education 2024," Sophos, Tech. Rep., 2024. [Online]. Available: https://www.sophos.com/en-us/blog/the-state-of-ransomware-in-education-2024

[2] J. B. Ulven and G. Wangen, "A systematic review of cybersecurity risks in higher education," *Future Internet*, vol. 13, no. 2, p. 39, 2021.

[3] J. Li, W. Xiao, and C. Zhang, "Data security crisis in universities: identification of key factors affecting data breach incidents," *Humanities and Social Sciences Communications*, vol. 10, p. 270, May 2023.

[4] Q. Liu and M. Khalil, "Understanding privacy and data protection issues in learning analytics using a systematic review," *British Journal of Educational Technology*, vol. 54, no. 6, pp. 1715–1747, Nov. 2023.

[5] J. Fernandes, C. Machado, and L. Amaral, "Identifying critical success factors for the general data protection regulation implementation in higher education institutions," *Digital Policy, Regulation and Governance*, vol. 24, no. 4, pp. 355–379, 2022.

[6] Semana, "Los detalles secretos del grave hackeo que sufrió la Universidad Nacional," Apr. 2023. [Online]. Available: https://www.semana.com/nacion/articulo/asi-fue-el-hackeo-del-que-fue-victima-la-universidad-nacional/202335/

[7] CNN Chile, "Hackeo a la Universidad Santa María: datos de estudiantes y académicos fueron vulnerados y publicados en la dark web," Nov. 2024. [Online]. Available: https://www.cnnchile.com/pais/hackeo-universidad-santa-maria-datos-estudiantes-academicos-vulnerados-publicados-dark-web_20241116/

[8] T. D. Zappelini, L.-M. Schippers, and A. P. da Silva, "Personal data of adolescents in higher education: The LGPD and the use of digital media for teaching activities and remote testing," *Revista Direito GV*, vol. 19, p. e2335, 2023.

[9] Y. Arciniegas, “Falla informática en Ecuador: los datos de casi toda la población quedaron expuestos,” France 24, Sep. 2019. [Online]. Available: https://www.france24.com/es/20190917-ecuador-datos-expuestos-informacion-filtracion

[10] Asamblea Nacional del Ecuador, “Ley Orgánica de Protección de Datos Personales,” Registro Oficial Quinto Suplemento N.º 459, Quito, Ecuador, May 2021.

[11] Presidencia de la República del Ecuador, “Reglamento General a la Ley Orgánica de Protección de Datos Personales (Decreto Ejecutivo N.º 904),” Registro Oficial Tercer Suplemento N.º 435, Quito, Ecuador, Nov. 2023.

[12] Superintendencia de Protección de Datos Personales, “Guía de Gestión de Riesgos y Evaluación de Impacto del Tratamiento de Datos Personales,” Resolución N.º SPDP-SPD-2025-0003-R, 29 de abril de 2025. Registro Oficial Cuarto Suplemento N.º 41, 19 de mayo de 2025, Quito, Ecuador, 2025. [Online]. Available: https://spdp.gob.ec/wp-content/uploads/2025/05/03.01.01-SPDP-SPD-2025-0003-R-Guia-Gest-de-Riesg-y-Ev-Imp-signed.pdf

[13] Lexis, “Registro Oficial del día: Superintendencia expide guía para gestión de riesgos y evaluación de impacto en tratamiento de datos personales,” 2025. [Online]. Available: https://www.lexis.com.ec/noticias/registro-oficial-del-dia-superintendencia-expide-guia-para-gestion-de-riesgos-y-evaluacion-de-impacto-en-tratamiento-de-datos-personales

[14] Superintendencia de Protección de Datos Personales, “Guía de Gestión de Riesgos y Evaluación de Impacto del Tratamiento de Datos Personales, Versión 2,” Resolución N.º SPDP-SPD-2026-0012-R. Registro Oficial Suplemento N.º 254, 30 de marzo de 2026, Quito, Ecuador, 2026. [Online]. Available: https://spdp.gob.ec/wp-content/uploads/2026/03/ggrispdp2026v2.pdf

[15] ——, “Norma General sobre el Tratamiento de Datos Personales a Gran Escala,” Resolución N.º SPDP-SPD-2026-0005-R, Registro Oficial Suplemento N.º 231, 25 de febrero de 2026, Quito, Ecuador, 2026.

[16] R. Revelo, “Superintendencia de datos sanciona a LigaPro y FEF por infracciones en el tratamiento de datos personales,” Primicias, Dec. 2025. [Online]. Available: https://www.primicias.ec/deportes/futbol/superintendencia-datos-sanciona-ligapro-fef-infracciones-tratamiento-datos-personales-110763/

[17] ECIJA GPA, “Primeras sanciones por vulneración de datos en Ecuador,” Dec. 2025. [Online]. Available: https://www.ecija.com/actualidad-insights/primeras-sanciones-por-vulneracion-de-datos-en-ecuador/

[18] M. Almeida and P. Mena Mena, “Cero sanciones en Ecuador por una ley de protección de datos personales blandengue,” Primicias, Sep. 2025. [Online]. Available: https://www.primicias.ec/politica/cero-sanciones-ecuador-ley-proteccion-datos-personales-blandengue-104527/

[19] J. A. Álvarez-Carrión and G. P. Hernández-Sotomayor, “Protección de datos personales en plataformas educativas digitales en el sistema de educación superior de Ecuador,” *MQRInvestigar*, vol. 8, no. 3, pp. 5324–5339, 2024.

[20] P. O. Piray Rodríguez, S. W. Parra Molina, J. E. Yaulema Colcha, and J. J. Salazar Briones, “Garantías jurídicas de la privacidad informativa en instituciones de educación superior del Ecuador contemporáneo,” *Universidad y Sociedad*, vol. 18, no. 2, p. e5877, 2026. [Online]. Available: https://rus.ucf.edu.cu/index.php/rus/article/view/5877

[21] F. López-Vasco, M. Angulo-Alvarez, D. I. Sosa Zuñiga, E. Puente Moromenacho, N. Ortiz *et al.*, “Application of ISO/IEC 27,001 in higher education technological institutes: Case-control study,” in *Developments and Advances in Defense and Security (MICRADS 2024)*, ser. Smart Innovation, Systems and Technologies, vol. 423. Singapore: Springer, 2025, pp. 179–189.

[22] M. Deng, K. Wuyts, R. Scandariato, B. Preneel, and W. Joosen, “A privacy threat analysis framework: supporting the elicitation and fulfillment of privacy requirements,” *Requirements Engineering*, vol. 16, no. 1, pp. 3–32, 2011.

[23] F. Bieker, M. Friedewald, M. Hansen, H. Obersteller, and M. Rost, “A process for data protection impact assessment under the European General Data Protection Regulation,” in *Privacy Technologies and Policy (APF 2016)*, ser. Lecture Notes in Computer Science, vol. 9857. Cham: Springer, 2016, pp. 21–37.

[24] K. Vemou and M. Karyda, “Evaluating privacy impact assessment methods: guidelines and best practice,” *Information and Computer Security*, vol. 28, no. 1, pp. 35–53, 2020.

[25] S. Wairimu, L. H. Iwaya, L. Fritsch, and S. Lindskog, “On the evaluation of privacy impact assessment and privacy risk assessment methodologies: A

systematic literature review," *IEEE Access*, vol. 12, pp. 19 625–19 650, Feb. 2024.

[26] L. H. Iwaya, A. S. Alaqra, M. Hansen, and S. Fischer-Hübner, "Privacy impact assessments in the wild: A scoping review," *Array*, vol. 23, p. 100356, Sep. 2024.

[27] S. Wairimu, L. H. Iwaya, L. Fritsch, and S. Lindskog, "Understanding practitioner perspectives on using privacy harm categories for privacy risk assessment," *Journal of Information Security and Applications*, vol. 93, p. 104174, Sep. 2025.

[28] J. Wang, M. Neil, and N. Fenton, "A bayesian network approach for cybersecurity risk assessment implementing and extending the FAIR model," *Computers & Security*, vol. 89, p. 101659, Feb. 2020.

[29] S. Patiño, E. F. Solís, S. G. Yoo, and R. Arroyo, "ICT risk management methodology proposal for governmental entities based on ISO/IEC 27005," in *2018 International Conference on eDemocracy & eGovernment (ICEDEG)*. Ambato, Ecuador: IEEE, 2018, pp. 75–82.

[30] M. E. Gursoy, A. Inan, M. E. Nergiz, and Y. Saygin, "Privacy-preserving learning analytics: Challenges and techniques," *IEEE Transactions on Learning Technologies*, vol. 10, no. 1, pp. 68–81, 2017.

[31] A. Habbabeh, B. Schneider, and P. M. Asprion, "Data privacy assessment: An exemplary case for higher education institutions," *International Journal of Management, Knowledge and Learning*, vol. 8, no. 2, pp. 221–241, 2019. [Online]. Available: https://www.issbs.si/press/ISSN/2232-5697/8_221-241.pdf

[32] E. Vanezi, D. Kouzapas, G. M. Kapitsaki, T. Costi, A. Yeratziotis, C. Mettouris, A. Philippou, and G. A. Papadopoulos, "GDPR compliance in the design of the INFORM e-learning platform: A case study," in *2019 13th International Conference on Research Challenges in Information Science (RCIS)*. Brussels, Belgium: IEEE, May 2019, pp. 1–12.

[33] Y.-S. Tsai, A. Whitelock-Wainwright, and D. Gašević, "The privacy paradox and its implications for learning analytics," in *Proceedings of the 10th International Conference on Learning Analytics & Knowledge (LAK '20)*. Frankfurt, Germany: ACM, Mar. 2020, pp. 230–239.

[34] K. Maguraushe, A. Da Veiga, and N. Martins, “Assessing information privacy awareness, expectations, and confidence of students: Evidence from a diagnostic survey in a developing country’s higher education sector,” *Journal of Cybersecurity and Privacy*, vol. 6, no. 2, p. 62, Apr. 2026.

[35] C. Guerrero Argote, “Impacto en la privacidad a partir del uso de tecnologías de e-proctoring en la región de Latinoamérica: estudio del caso en universidades de Argentina, Chile y Perú,” *Revista Latinoamericana de Economía y Sociedad Digital*, no. 2, 2021.

[36] *Information technology – Security techniques – Guidelines for privacy impact assessment*, International Organization for Standardization Std. ISO/IEC 29 134:2023, May 2023. [Online]. Available: https://www.iso.org/standard/86012.html

[37] Agencia Española de Protección de Datos, “Gestión del riesgo y evaluación de impacto en tratamientos de datos personales,” Guía, Madrid, Jun. 2021. [Online]. Available: https://www.aepd.es/guias/gestion-riesgo-y-evaluacion-impacto-en-tratamientos-datos-personales.pdf

[38] K. R. Boeckl and N. B. Lefkovitz, “NIST privacy framework: A tool for improving privacy through enterprise risk management, version 1.0,” National Institute of Standards and Technology, Gaithersburg, MD, Cybersecurity White Paper CSWP 01162020, Jan. 2020.

[39] European Union Agency for Network and Information Security, “Recommendations for a methodology of the assessment of severity of personal data breaches,” ENISA, Working document v1.0, Dec. 2013. [Online]. Available: https://www.enisa.europa.eu/publications/dbn-severity

[40] Superintendencia de Industria y Comercio, “La SIC presenta una guía para fortalecer la protección de los datos personales en las Instituciones de Educación Superior,” Comunicado de prensa, Bogotá, Colombia, Aug. 2026. [Online]. Available: https://sedeelectronica.sic.gov.co/comunicado/la-sic-presenta-una-guia-para-fortalecer-la-proteccion-de-los-datos-personales-en-las-instituciones-de-educacion-superior

[41] *Information security, cybersecurity and privacy protection – Guidance on managing information security risks*, International Organization for Standardization Std. ISO/IEC 27 005:2022, Oct. 2022. [Online]. Available: https://www.iso.org/standard/80585.html

[42] *Risk management – Guidelines*, International Organization for Standardization Std. ISO 31 000:2018, 2018. [Online]. Available: https://www.iso.org/standard/65694.html

[43] *Information security, cybersecurity and privacy protection – Privacy information management systems – Requirements and guidance*, International Organization for Standardization Std. ISO/IEC 27 701:2025, Oct. 2025. [Online]. Available: https://www.iso.org/standard/27701

[44] A. R. Hevner, S. T. March, J. Park, and S. Ram, "Design science in information systems research," *MIS Quarterly*, vol. 28, no. 1, pp. 75–105, 2004.

[45] J. Humble and D. Farley, "Continuous delivery and devops: A practical approach," in *Agile Conference*, 2011.

GLOSARIO

[Defina los términos técnicos relevantes utilizados en el documento.]

Término o sigla 1 *[Definición técnica breve y clara.]*

Término o sigla 2 *[Definición técnica breve y clara.]*

ANEXO A

TÍTULO DEL ANEXO A

[Incluya una descripción breve del contenido del anexo. Ejemplo: documentación técnica, diagramas, configuraciones, evidencias o instrumentos aplicados.]

- *[Documentación técnica.]*
- *[Manuales de usuario y administración.]*
- *[Evidencias de pruebas.]*
- *[Autorizaciones y validaciones de la entidad receptora.]*
- *[Repositorio de versionamiento (enlace).]*
- *[Formatos de entrevistas y encuestas aplicadas.]*